

МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ
НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ «ПОЛТАВСЬКА ПОЛІТЕХНІКА
ІМЕНІ ЮРІЯ КОНДРАТЮКА»

Навчально науковий інститут інформаційних технологій і робототехніки
Кафедра комп'ютерних та інформаційних технологій і систем

Лабораторне заняття №4
з навчальної дисципліни
"Технології розробки корпоративних Web-додатків"

Виконав:

студент 401-ТН

Стефанович Богдан Ігорович

Перевірив:

Тютюнник Петро Богданович

Полтава – 2026

Завдання

Мета роботи — захистити API від несанкціонованого доступу, реалізувати механізм реєстрації та входу користувачів, а також розмежувати права доступу на основі ролей.

1. Реалізація моделі користувача та безпечного зберігання паролів

- Розширте базу даних сутністю User (Користувач) та Role (Роль), якщо їх ще немає.
- Вимога: Паролі користувачів заборонено зберігати у відкритому вигляді.
- Реалізуйте механізм хешування паролів перед збереженням у БД (використовуйте алгоритми BCrypt, Argon2 або PBKDF2).
- Реалізуйте ендпоінт для реєстрації нового користувача (Sign Up), який приймає логін/email та пароль, хешує пароль і зберігає користувача в БД.

2. Реалізація автентифікації (Authentication)

- Реалізуйте механізм входу в систему (Sign In).
- Створіть сервіс, який перевіряє валідність наданих облікових даних (порівнює хеш введеного пароля з хешем у БД).
- Оберіть механізм управління сесією. Для REST/GraphQL API рекомендовано використовувати JWT (JSON Web Tokens):
 - При успішному вході сервер має генерувати підписаний токен (Access Token), який містить ID користувача та його Role.
 - Токен має мати обмежений термін дії (наприклад, 15-60 хвилин).

3. Реалізація авторизації (Authorization) та Middleware

- Реалізуйте механізм перехоплення запитів (Middleware, Interceptor або Filter), який перевіряє наявність та валідність токена в заголовках запиту (зазвичай Authorization: Bearer <token>).
- Захистіть маршрути (Endpoints) вашого API:
 - Public routes: Доступні всім (наприклад, реєстрація, логін, перегляд списку товарів).
 - Authenticated routes: Доступні тільки авторизованим користувачам (наприклад, створення замовлення, редагування профілю).
 - Admin routes: Доступні тільки користувачам з роллю Admin (наприклад, видалення товарів, керування користувачами).

4. Інтеграція з поточним API

- Модифікуйте контролери з Лаб №3.
- Спробуйте виконати запит до захищеного ресурсу без токена і переконайтеся, що отримуєте помилку 401 Unauthorized.
- Спробуйте виконати запит до адміністративного ресурсу зі звичайним користувачем і переконайтеся, що отримуєте помилку 403 Forbidden.

Очікуваний результат (Звіт та код):

1. Посилання на Git-репозиторій.
2. Скріншоти з Postman/Swagger:
 - a. Успішна реєстрація (створення користувача).
 - b. Успішний логін (отримання JWT токена у відповідь).
 - c. Знімок БД, де видно, що поле Password містить хеш, а не відкритий текст.
 - d. Запит без токена -> статус 401 Unauthorized.
 - e. Запит з токеном звичайного юзера до адмін-панелі -> статус 403 Forbidden.
 - f. Успішний запит до захищеного ресурсу з валідним токеном.

Виконання

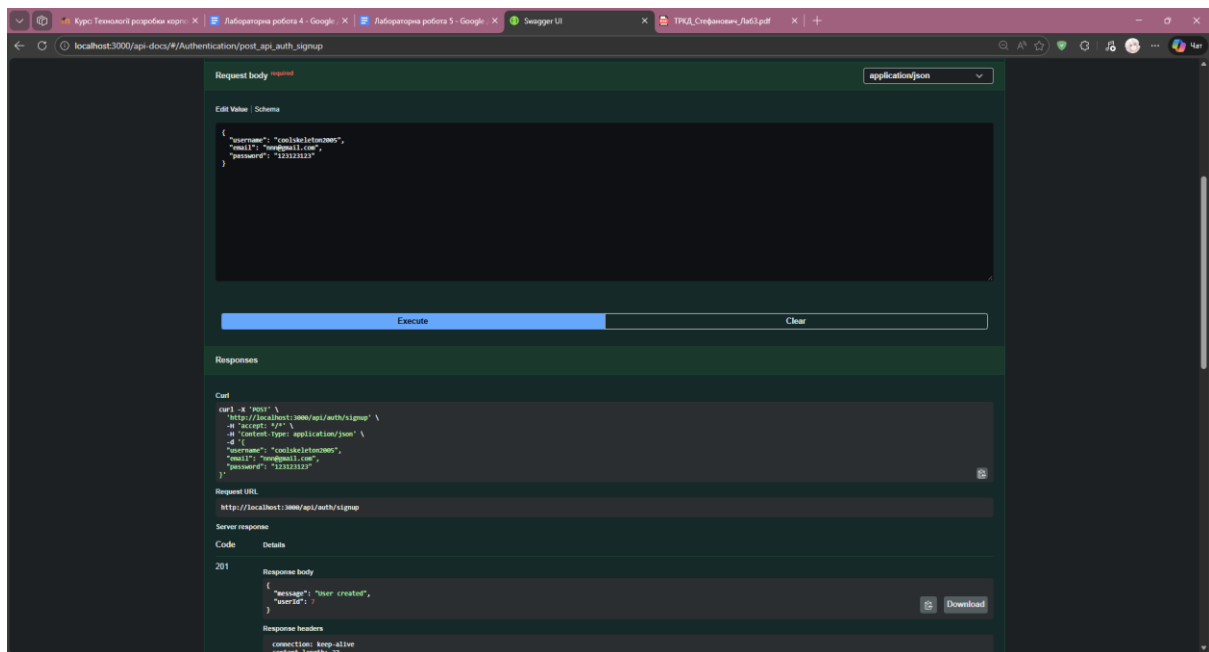


Рис. 1. – Результат виконання запиту реєстрації користувача

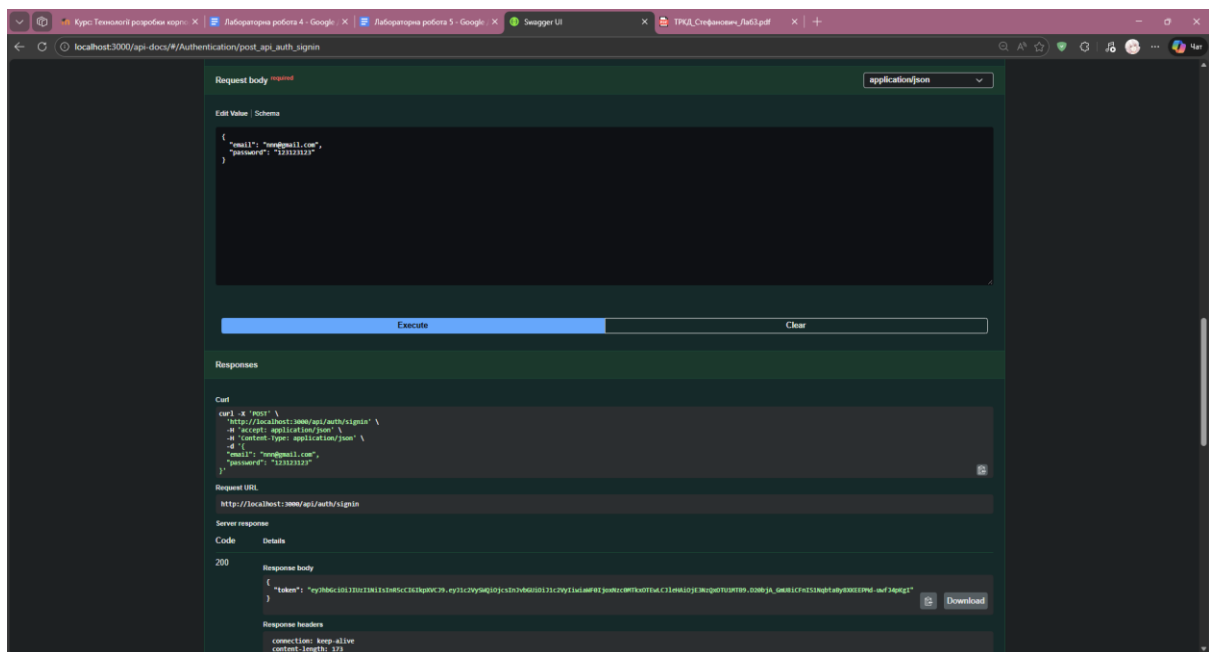


Рис. 2. – Результат виконання запиту автентифікації користувача з генерацією токена

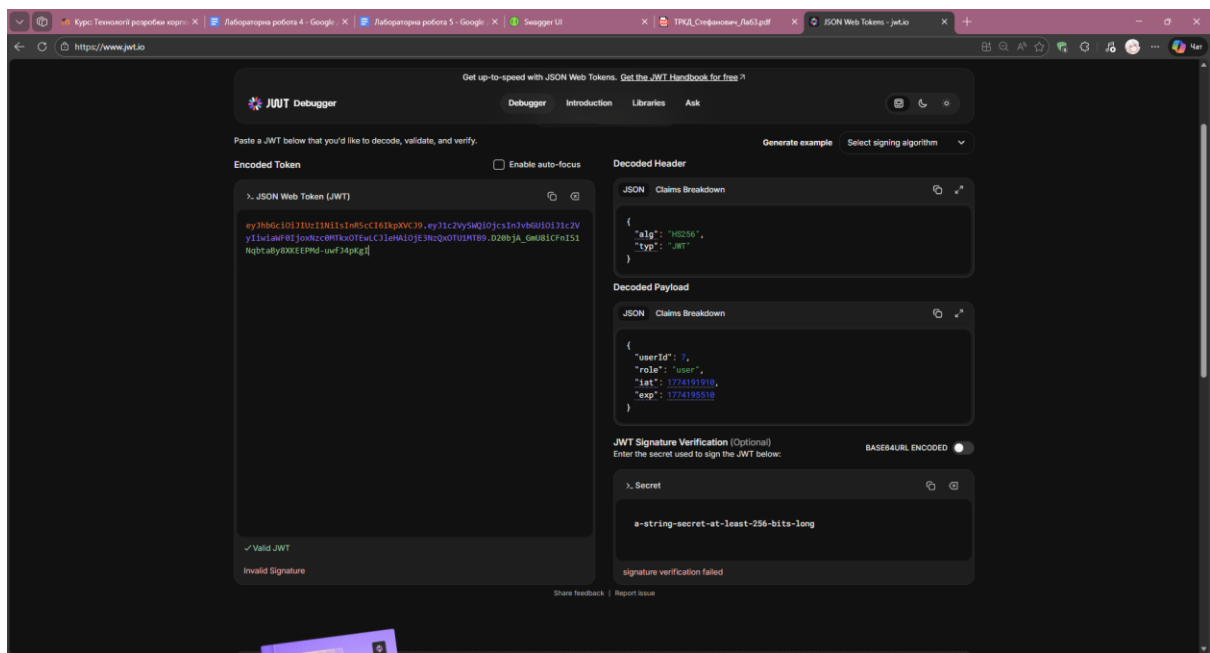


Рис. 3. – Зміст токєну

7 coolskelton2005 nnn@gmail.com \$2b\$10\$ofQMfYVlnwOjRimZB/OWzOO61bhKD1... user 2026-03-22 15:04:26

Рис. 4. – Утворений юзер у БД із захешованим паролем

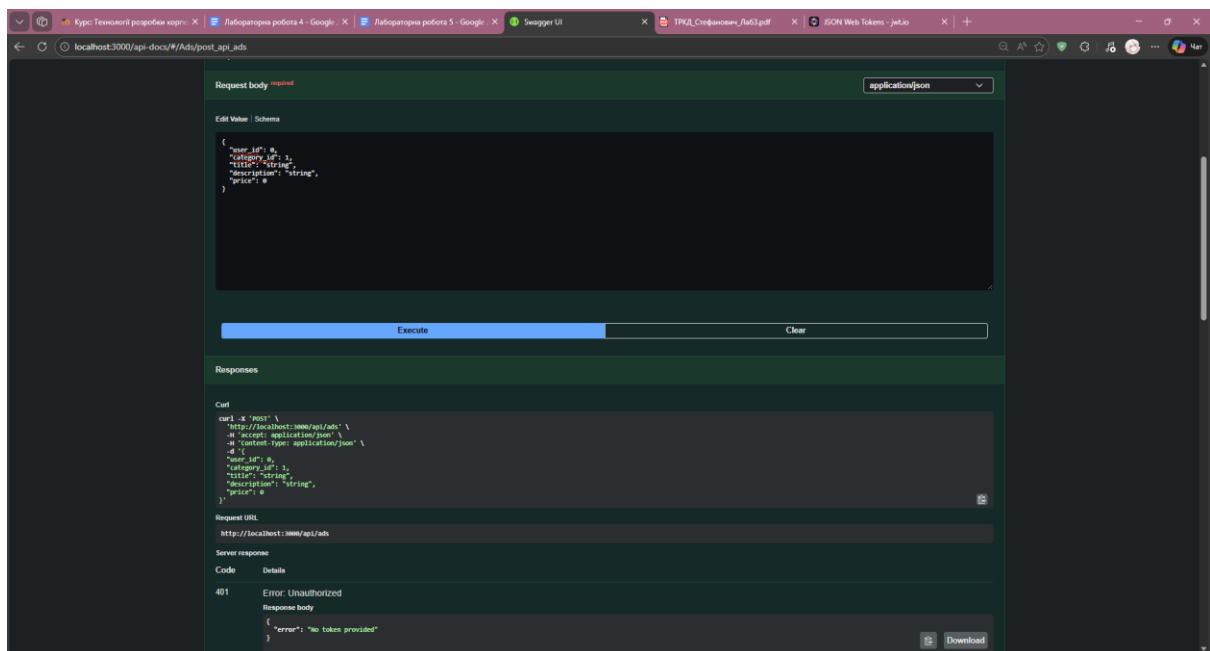


Рис. 5. – Запит без токєну

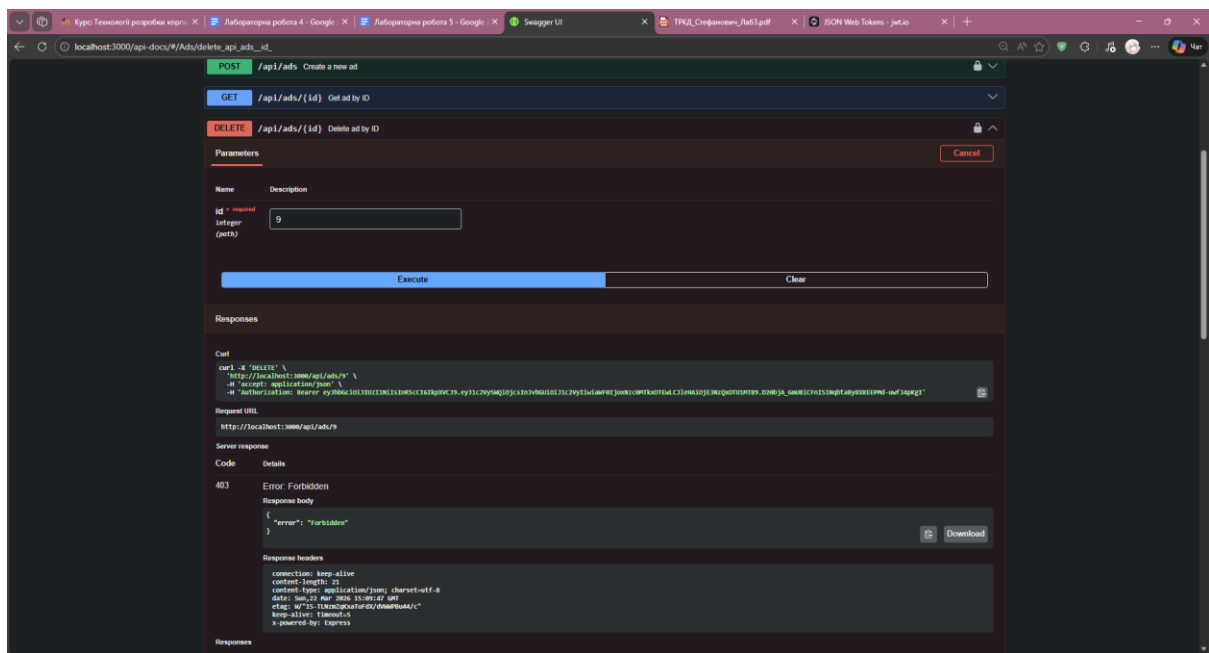


Рис. 6. – Запит без привілеїв

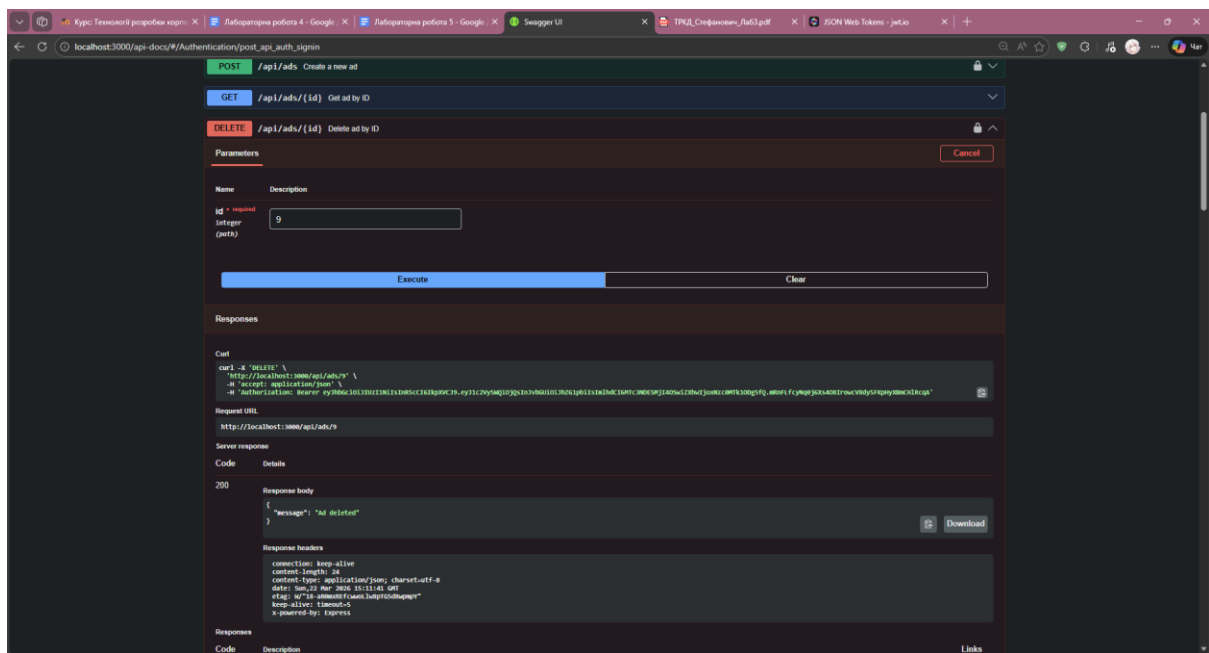


Рис. 7. – Запит з привілеями

Посилання на репозиторій

[verdevia/TRVD_2026_401TN_Stefanovych_Labs_at_lab4](https://github.com/verdevia/TRVD_2026_401TN_Stefanovych_Labs_at_lab4)